Lab 49 — Passive Reconnaissance / OSINT

> **SY0-701 Objective 5.5** — Explain types and purposes of audits and assessments
>
> **Domain 5** — Security Program Management and Oversight (20%) · **Time:** ~25 min · **Course:** C628 CompTIA Security+ Exam Prep

Goal: Build a public footprint of a domain using only passive sources — no packet ever reaches the target.

You'll build: A passive reconnaissance report for an authorised domain, assembled from WHOIS, DNS, certificate transparency and passive subdomain discovery.

> **Authorised scope only.** Run reconnaissance only against a domain you own or are explicitly authorised to assess. Passive OSINT reads public records, but acting on it against systems you do not own can breach the **Singapore Computer Misuse Act**. Keep all activity to `example.com` or your own domain.

Prerequisites: Killercoda Ubuntu Playground (root shell) — https://killercoda.com/playgrounds/scenario/ubuntu ; tools installed in step 1; network access.

Background

- **Reconnaissance** is the first phase of any assessment; in an **unknown environment** test the tester starts here.
- **Passive** recon never touches the target — it consumes pre-collected public data (registries, search engines, CT logs). It is the opposite of **active** recon (Lab 50), which sends traffic.
- **Certificate transparency** logs are the single richest passive source: they expose dev/staging hostnames teams forget.
- DNS TXT records (SPF, DMARC) reveal which third-party mail vendors a domain trusts — and where its email defences are weak.

Steps

1. Install the passive OSINT tools

The PyPI `theHarvester` is an abandoned stub, so install from source; grab the prebuilt `subfinder` binary.

```
apt-get update -qq && apt-get install -y whois dnsutils python3-pip jq unzip curl
pip3 install --break-system-packages git+https://github.com/laramies/theHarvester.git
SF=$(curl -s https://api.github.com/repos/projectdiscovery/subfinder/releases/latest |
grep -oP '"tag_name": "v\K[^"]+')
curl -sL
"https://github.com/projectdiscovery/subfinder/releases/download/v${SF}/subfinder_${SF}_li
nux_amd64.zip" -o /tmp/sf.zip
unzip -o /tmp/sf.zip subfinder -d /usr/local/bin/ && chmod +x /usr/local/bin/subfinder
```

2. Set an authorised target domain

Use a domain you own or one explicitly authorised; `example.com` is always safe to demonstrate.

```
TARGET=example.com
echo "Target: $TARGET"
```

3. Query WHOIS registrant and dates

WHOIS shows registrar, creation/expiry dates and name servers (privacy proxies may hide contacts).

```
whois "$TARGET" | grep -Ei "registrar|registrant|expir|name server" | head
```

4. Enumerate DNS records (MX, TXT, NS)

Mail and policy records map the estate and reveal email-security gaps.

```
dig +short MX "$TARGET"
dig +short TXT "$TARGET"
dig +short TXT "_dmarc.$TARGET"
dig +short NS "$TARGET"
```

5. Discover subdomains passively with subfinder

Subfinder queries 25+ public sources without touching the target.

```
subfinder -silent -d "$TARGET" | tee subs.txt
wc -l subs.txt
```

6. Harvest emails and hosts

theHarvester aggregates public email addresses and hostnames.

```
theHarvester -d "$TARGET" -b crtsh,duckduckgo,bing 2>/dev/null | tail -30
```

7. Pull certificate transparency records

Every certificate ever issued for the domain is public — including forgotten hostnames.

```
curl -s "https://crt.sh/?q=%25.$TARGET&output=json" | jq -r '.[].name_value' | sort -u |
head -20
```

8. Build the recon report

Summarise the footprint into the report that scopes the rest of the assessment.

```
cat > "recon-$TARGET.md" <<EOF
# Passive Recon Report — $TARGET
- Subdomains found: $(wc -l < subs.txt)
- DMARC: $(dig +short TXT _dmarc.$TARGET | head -1)
- SPF: $(dig +short TXT $TARGET | grep -i spf | head -1)
```

```
- Packets sent to target: 0 (all data from public sources)
EOF
cat "recon-$TARGET.md"
```

Test it

```
cat "recon-example.com.md"
wc -l subs.txt
```

Expected: `recon-example.com.md` lists the subdomain count plus the domain's DMARC and SPF records, and records that zero packets were sent to the target.

Troubleshooting

Symptom	Fix
`subfinder: command not found`	The release download/unzip failed; re-run step 1 (check network / GitHub reachability).
`theHarvester` errors on a source	Source APIs rate-limit; drop to `-b crtsh` only, or re-run later.
`crt.sh` returns nothing	The service is occasionally slow; retry, or query it in a browser.

Challenge

Run the same workflow against your own organisation's domain and list one hostname or record you would want taken down or hardened.

Reflection

Objective 5.5 contrasts passive and active reconnaissance. Why can passive recon be run before authorisation paperwork is finalised, while the Lab 50 scans cannot?

Exam tips

- Passive recon sends **no packets** to the target; it leaves nothing in the target's logs.
- Certificate transparency is the richest passive source for discovering forgotten subdomains.
- Recon is the opening phase of a known/partially known/unknown environment test.
- Authorisation (rules of engagement) comes before any *active* step — passive reads public data.

References

- crt.sh certificate transparency — https://crt.sh
- OSINT Framework — https://osintframework.com
- MITRE ATT&CK Reconnaissance (TA0043) — https://attack.mitre.org/tactics/TA0043/
- Singapore Computer Misuse Act — https://sso.agc.gov.sg/Act/CMA1993
